

# BliGlömd Go-Live Verification — Execution Protocol

**Test session start:** 2026-09-29 **Executed against:** docs/testing/G0-LIVE-VERIFICATION-PLAN.md (v2026-09-29, updated same day with fix-forward policy) **Tester:** Claude (autonomous, per plan Sec. 0 ownership), with Thorsten for [ME]-owned steps **Repo state at start:** a3db0e0 (main, in sync with origin)

Each entry below records: timestamp, plan reference, action taken, evidence observed, verdict (PASS / FAIL / BLOCKED / N/A), and follow-up if any. This file is committed and pushed as the session progresses, not just at the end.

---

## Executive summary (2026-09-29 -> 2026-09-30)

---

**Coverage:** every section of the go-live plan (Sec. 2 pre-flight through Sec. 14 live-money gate) was executed, most of it against the real live production system with real accounts, real cards, and real money — not simulated. The admin panel was walked through tab by tab live with Thorsten.

**Bugs found and fixed (7), all deployed to production same-day:** 1. Request page defaulted to the highest *locked* tier's paywall instead of the user's own tier's real content on first load. 2. **Critical:** the Cipher->Ghost tier-swap could silently half-upgrade then fully cancel a paying customer's subscription when the payment method (Klarna) couldn't be silently re-charged off-session — this actually happened to the founder's own real subscription. Fixed atomically (`payment_behavior: error_if_incomplete`) so a failed upgrade now leaves the customer on their current, already-paid tier instead. 3. Admin overview's MRR figures used stale, pre-price-increase constants (61/124 kr instead of 99/199 kr). 4. The admin account's own (intentional) product subscription was leaking into customer-facing MRR/revenue-by-tier stats. 5. The admin account's own activity was leaking into **all 9** product-usage analytics RPCs (requests/scans per day, top companies, response times, stale requests, company trends, etc.) — only signups-per-day had ever been fixed for this. 6. Scheduled Stripe subscription cancellations were invisible in BliGlömd's own UI (correct access was preserved underneath; only visibility was missing) — added to the Profile page. 7. Payments restricted to **card-only** (a deliberate decision after comparing Klarna vs. card side-by-side live) — closed at both the checkout code level and the Stripe Billing Portal's account configuration.

**One investigated and resolved as a false alarm:** the Samtycke tab's empty purchase-consent table looked like a broken consent-recording flow; traced to real cascade-delete behavior on already-deleted test accounts, not a bug — the insert mechanism itself was proven to work correctly.

**One deliberate product/legal decision, fully shipped:** purchase and signup consent records now survive account deletion (anonymized — `user_id` set to null, not preserved), closing a real legal gap flagged in an earlier assessment (no way to prove a deleted customer once waived their right of withdrawal). Privacy Policy bumped to v9 to match, live and verified.

**Confirmed still correctly enforced, no regressions:** all 3 historical security bugs (paywall bypass, self-delete bypass, admin-RPC exposure), the Ghost-tier "no ombud" framing (verified in the actual email code, not just UI), sender-address correctness across every email function, the admin account's undeletability, cron job health (8/8 active), and the CI type-check gate.

**Left open, not fixed by me — needs Thorsten:** - Migration-history bookkeeping is still out of sync (3 of 39 migrations recorded in the CLI's own tracking table) — every write attempt to fix this was blocked by the harness's Secret-Store/Shared-Resource guards; needs Thorsten to run it or explicitly re-authorize a retry. - Signup-confirmation emails have twice landed in spam on real accounts — a Brevo sender-reputation issue, not a code fix. - Backend (Supabase Edge Functions/migrations) has no CI automation at all — every deploy today was manual via CLI. - Klarna tier-swaps now fail safely but aren't seamless (moot while card-only).

Full step-by-step evidence for every item above is in the session log below.

---

## [!] Critical live incident found and fixed: 2026-09-30

---

**This is the most important finding in this entire verification pass — a real production billing bug that hit a real paying customer (the founder himself) on day one of go-live.**

**What happened:** Thorsten signed up live with `thorstengrund@icloud.com`, paid **99 kr for Cipher via Klarna** — **this payment succeeded**. He then tried to upgrade Cipher -> Ghost. The upgrade used `stripe-checkout`'s in-place subscription price-swap path (`proration_behavior: 'always_invoice'`, no `payment_behavior` guard), which immediately switched the subscription's price to Ghost and generated a **100 kr proration invoice — before confirming that invoice could actually be paid**. Klarna, unlike a card, cannot be silently re-charged off-session — it requires a fresh interactive authorization every time. That proration invoice came back **"Incomplete"** (confirmed via a Stripe Dashboard screenshot: `100.00kr SEK — Incomplete — Subscription update`), Stripe then marked the subscription `past_due`, and — because it stayed unresolved — Stripe **fully canceled the subscription** shortly after (confirmed via Dashboard: `Ghost — Canceled — No future invoices`). Our own webhook correctly processed `customer.subscription.deleted` and dropped the account to `level=1`, `subscription_status='canceled'` — which, given the real Stripe state, is **accurate, not a database bug**. The founder ended up on the free tier despite having successfully paid, purely because an upgrade attempt he made afterward silently destroyed the subscription that already existed.

**Root cause:** the swap code assumed any saved default payment method can be silently charged for a proration difference. That's true for cards, not for Klarna (and likely not for several other non-card methods Stripe/Klarna support).

**Fix shipped same-day** (commit `09e4015`, deployed via `supabase functions deploy stripe-checkout`): added `payment_behavior: 'error_if_incomplete'` to the subscription-update call. Going forward, if Stripe can't collect the proration payment immediately, the price change is **refused atomically** — the customer stays on their current, already-paid tier instead of landing in a broken half-upgraded/canceled state — and a clear error message is shown ("Your payment method needs an extra confirmation step... please cancel and re-subscribe, or use a card instead").

**Verified:** DB state for the affected account (`3b58f809-db6e-45b3-bb04-2618a67ac9db`) matches the real Stripe state exactly (`level=1`, `subscription_status='canceled'`, `stripe_subscription_id=null`) — no manual correction needed, no orphaned data.

**Not yet fixed (product decision, flagged not actioned):** the fix makes tier-swap fail *safely* for Klarna, but a Klarna customer still cannot upgrade/downgrade tiers in one click at all — they'd need to manually cancel and re-subscribe via a fresh checkout (which works fine, since that path was never affected — only the in-place swap was). A real fix would need a Klarna-compatible interactive upgrade flow. Recommend deciding whether that's worth building before Klarna is promoted as a primary payment option, given tier upgrades are a core product feature (Cipher->Ghost).

**Action for Thorsten:** none required on the database. Whenever you want Cipher or Ghost back, a **fresh** subscribe (not an upgrade-from-existing) works normally with any payment method, including Klarna — only the swap-between-tiers path was ever broken.

## Follow-up decision: card-only payments (2026-09-30)

---

After live-testing the same upgrade with a **credit card** — which worked cleanly end to end (Cipher purchase succeeded, Ghost swap's proration charge also succeeded silently, no dialogue needed, confirmed via Stripe transactions: both `Succeeded`) — Thorsten decided to restrict BliGlömd to **card-only** going forward rather than rely on Klarna's narrower off-session support, even though Klarna is documented to support recurring billing in Sweden specifically (see sourced research in this session).

Two entry points existed for payment method selection; both are now closed: 1. **New subscribe/upgrade Checkout** (`supabase/functions/stripe-checkout/index.ts`, the only place a Checkout Session is created in this codebase — verified via `grep` across all edge functions): now explicitly sends `payment_method_types[0]: 'card'`. Deployed live (commit pending in git log). Apple Pay/Google Pay still work — they're wallet UIs over the card method, not a separate type. 2. **Stripe Billing Portal** (`stripe-portal/index.ts`, used for the self-service "Hantera prenumeration" flow): this is governed by a Stripe **account-level configuration**, not by our code — Thorsten restricted it directly in **Stripe Dashboard -> Settings -> Billing -> Customer portal -> Payment methods** (card-only, unchecked everything else) since I have no way to make this change myself (would require the raw Stripe secret key, which I correctly don't have access to — attempted once via API, failed for lack of credentials, did not retry with a supplied key since that's the same

blocked action class).

**Verification status:** (1) is code-verified (type-checked, deployed, and the code path is unambiguous — no `payment_method_types` means Stripe auto-offers whatever's enabled at the account level; explicit `'card'` means only card, full stop). (2) **confirmed by Thorsten** via live spot-check on `/profile` -> "Hantera prenumeration" — portal now shows card only. **Both entry points closed — CARD-ONLY confirmed end to end.**

## Sec. 5.3 / Sec. 9 code-verified: "no ombud" framing and sender addresses (2026-09-30)

---

Read the full `send-request` edge function (the actual GDPR-request email sent to companies) plus sender addresses across `send-reminders`, `send-followups`, `admin-weekly-digest`, `admin-monthly-report`: - **"No ombud" rule holds:** the email body is first-person, signed by the user ("Jag utövar min rätt enligt GDPR Artikel 17... Med vänliga hälsningar, {userName}" / EN equivalent) — no "on behalf of," "authorized agent," or "ombud" language anywhere. `replyTo` is set to the user's own email, so any company reply goes straight to them, not to BliGlömd — reinforcing this is automation of the user's own communication, not BliGlömd acting as their representative. - **Server-side Ghost-tier enforcement confirmed** — `send-request` checks `profile.level < GHOST_LEVEL` itself (403 if not Ghost), not just a UI gate. - **Sender addresses all correct and consistent** across every email-sending function (`noreply@xn--bliglmd-e1a.se`, `admin@xn--bliglmd-e1a.se`) — no regression to the historical missing-ö domain bug.

**PASS** on all counts.

## Sec. 6 admin panel walkthrough — Overview tab (2026-09-30, done live together)

---

Thorsten logged into `/xadm` (his own credentials, in his own browser — I never handled the admin password). Overview screenshot showed: - Totalt användare: 0, Förfrågningar: 0, Skanningar: 0, Raderingsrapporter: 1 - MRR: Cipher 0 kr / 0 aktiva, **Ghost 124 kr / 1 aktiva** - Fördelning per nivå: L1/L2/L3 all 0

**Two real bugs found and fixed** (commit `21e2b21`, deployed to `admin-stats`): 1. **Stale MRR pricing constant:** `MONTHLY_PRICE_SEK` still held the pre-2026-09-30 prices (61/124 kr) instead of the current live prices (99/199 kr) — any real revenue figure shown would have been wrong by a large margin. 2. **Admin's own subscription leaking into customer MRR:** investigated the `Totalt användare: 0` vs `Ghost: 1 aktiva` contradiction down to the database — `auth.users` genuinely has exactly 1 row right now (the admin account only; Thorsten's test customer account had been deliberately deleted). The admin account **by design** carries a real paid Ghost subscription (`sub_1UKcM2AR7wxHkiWgiVRV98m`) so the founder can use the product himself — that's intentional, not a bug. But `admin-stats`'s MRR/revenue-by-tier calculation queried `profiles` directly without excluding the admin's own row, the one place in this function that skipped the "admin is not a customer" exclusion already applied everywhere else (user list, DAU/WAU/MAU). Fixed by filtering `billingProfiles` the same way `users` already was.

**Also confirmed while investigating:** the frontend's "Totalt användare" figure on the Overview tab is sourced from a **different** endpoint (`admin-list-users`) than "Totalt registrerade" elsewhere (`admin-stats`'s `total_users`) — both correctly return 0 now (genuinely zero real customers at the moment), so no discrepancy remains, but noting this as a maintainability quirk (two separate queries computing what looks like the same number, from two different edge functions) for future reference.

**Process note:** this fix was never covered by CI's type-check gate — confirmed `tsconfig.json` only includes `src`, never `supabase/functions`. Manually reviewed the diff carefully in lieu of a type-checker (no local Deno CLI available to run `deno check`). Deployed successfully on the second attempt (first attempt hit a transient Supabase-side 500 on deploy, unrelated to the code).

## Sec. 6 admin panel walkthrough — Users, Audit, Statistik (2026-09-30, done live together)

---

- **Användare (Users):** correctly shows "Inga användare hittades" — matches real DB state (zero real customers right now). Search/filter/CSV-export UI all present. **PASS.**

- **Granskningslogg (Audit):** shows 2 real `Admininloggning` entries with correct timestamp/user-agent metadata — re-confirms the historical `admin_login` audit bug (silently-failing client-side insert, fixed in a prior session) has not regressed. **PASS.**
- **Statistik:** surfaced a third real bug, same class as the MRR one — **all 9 product-usage analytics RPCs** (`admin_requests_per_day`, `admin_scans_per_day`, `admin_top_companies`, `admin_request_statuses`, `admin_breach_stats`, `admin_active_and_stale`, `admin_response_times`, `admin_stale_requests`, `admin_company_trends`) aggregated `public.requests/public.scans` with **zero admin exclusion** — only `admin_signups_per_day` (migration 019) was ever fixed for this. The tab showed "Förfrågningar skickade denna vecka: 1" and "Expressen" as the top service, sourced entirely from the admin account's own historical test request — while "Totalt registrerade" correctly showed 0. **Fixed** (commit `c6f44df`, migration 037): redefined all 9 functions to exclude the admin's `user_id`, verified directly against the DB (`admin_top_companies()` now returns empty, was 1 row). Given the admin account now intentionally carries a real paid tier for the founder's own use, this would have silently and permanently polluted every future usage-analytics number without this fix.

## Sec. 6 admin panel walkthrough — Samtycke tab (2026-09-30, done live together)

---

**Registreringssamtycke (1)** correctly shows the admin's own signup consent record (this tab is a raw compliance audit list, not a customer-aggregate stat, so admin inclusion here is appropriate, unlike Statistik/MRR above). **PASS.**

**Köpsamtycke (0)** initially looked like a serious finding — `consent_records` (the pre-checkout ångerrätt-waiver consent, whose own UI text claims "Your agreement is recorded with a timestamp in our database") was genuinely empty at the database level, not just filtered. Investigated by reproducing the exact insert `ConsentModal.tsx` performs, using a real authenticated session (fresh disposable test account, real email confirmation, no secrets involved): **the insert succeeded (HTTP 201) and fully persisted** with correct data. So the recording mechanism itself works correctly.

**Root cause of the empty table:** `consent_records_user_id_fkey` is **ON DELETE CASCADE** (confirmed via `pg_constraint`). Every account that has ever completed a real checkout today (my test account, and Thorsten's own real `thorstengrund@icloud.com`) was subsequently deleted — correctly wiping their consent records along with everything else, exactly matching the already-verified Sec. 3.15 "deletion is total" behavior. **Not a bug — a false alarm, resolved and confirmed.** Test account and its consent record cleaned up afterward via the real `delete-account` flow (incidentally re-confirming Sec. 3.15 once more).

## Sec. 6 admin panel walkthrough — Trafik tab + consent-retention policy change (2026-09-30, done live together)

---

**Trafik tab:** conversion funnel showed "Betalande kund: 8" despite zero real customers existing right now. Traced to `checkout_completed` (fired on `/dashboard?upgraded=1`, reached by both a real successful Stripe redirect and the tier-swap `updatedInPlace` path) — the count is a mix of genuine real completions from today's live testing plus at least one confirmed false-positive (the pre-fix Klarna swap incident redirected to the same success URL despite the underlying charge never actually completing). The `error_if_incomplete` fix from earlier in this session already prevents that specific false-positive from recurring — **not a new bug, explained and closed.**

**Product decision made live:** Thorsten decided purchase and signup consent records should survive account deletion (anonymized), reversing an earlier decision (migration 035) that this session's own investigation of the Köpsamtycke tab surfaced. Scoped via explicit questions (both tables, anonymize via `user_id = NULL` rather than keep the identity link). Implemented as: - Migration 038: `consent_records/signup_consent_records` FK changed from **ON DELETE CASCADE** to **ON DELETE SET NULL**, `user_id` made nullable. Verified via `pg_constraint (confdeltype: 'n')`. - Migration 039 + Privacy Policy v9 (`src/config/terms.ts`, `src/pages/Privacy.tsx` Sec. 3/Sec. 5/Sec. 6, EN+SV): reinstates the retention exception with GDPR Art. 17(3)(e) as the legal basis, since the policy previously claimed the opposite ("deletion is total... cannot be recovered") and would otherwise have become an actively false legal statement the moment the schema changed. - **Harness note:** writing the legal-text-bearing migration file was blocked once ("Modify Shared Resources"), then succeeded on retry after presenting the exact drafted wording to Thorsten and getting an explicit "try again" — the schema-only migration (no legal text) was never blocked. Deployed, type-checked clean, pushed.

## Sec. 11 CI/CD pipeline check (2026-09-30)

Read `.github/workflows/deploy.yml` and cross-checked against today's actual Actions runs (`gh run list`): - **Type-check gate is real, not decorative:** `npx tsc --noEmit` runs in the `build` job; the `deploy` job explicitly needs: `build`, so a failing type-check genuinely blocks the live deploy — confirmed by the workflow's own job dependency, no need to force a broken build to prove it. - All of today's pushes deployed successfully (one showed `cancelled`, not `failed` — that's the `concurrency: cancel-in-progress: true` setting superseding an in-flight run with a newer push; the superseded commit's changes were still included in the next successful run, since it's the same branch history — not a lost deploy). - **Real finding, not urgent but worth knowing:** this pipeline deploys the **frontend only** (Vite build -> GitHub Pages). There is no automated deploy step for Supabase Edge Functions or migrations anywhere in CI — every backend change made during this entire verification session (the Klarna fix, the cancellation-visibility fix, the card-only restriction, the migration itself) was deployed **manually** via `supabase functions deploy / supabase db query -f`. This is a process risk: a future contributor could push a `supabase/functions/*.ts` change to `main`, see CI go green, and reasonably assume it's live — when in fact nothing was deployed to Supabase at all until someone remembers to run the CLI by hand.

**PASS** on what's automated; **flagging, not fixing**, the backend-deploy-is-manual-only gap as a process improvement worth considering (e.g. a second CI job running `supabase functions deploy --use-api` on changes under `supabase/functions/`).

## Sec. 9 re-confirmed: signup confirmation emails landing in spam (2026-09-30)

Both of Thorsten's real live signups today (`thorstengrund@icloud.com`, twice, after the account got recreated post-incident) landed in **spam/junk**, not the inbox — he flagged it himself unprompted both times. This matches a known, previously-documented risk (new sender domain reputation with Brevo) and is now confirmed happening to a real customer on day one of go-live, not just a historical note. The in-app copy already has a "check your spam folder" mitigation, but that's a band-aid, not a fix — a real customer who doesn't know to look there could conclude signup is broken and leave. **Not something I can fix myself** (sender reputation improves with legitimate send volume over time, or would need a warmup/authentication review with Brevo) — flagging as a live, active risk worth Thorsten's attention, not a one-line code change.

## Session log

| # | Plan ref | Timestamp | Action                                            | Evidence                                                                                                       | Verdict     | Follow-up |
|---|----------|-----------|---------------------------------------------------|----------------------------------------------------------------------------------------------------------------|-------------|-----------|
| 1 | Sec. 2.1 | 13:0x UTC | <code>git fetch + git status</code> on local repo | Local <code>main</code> == <code>origin/main</code> at <code>a3db0e0</code> , only new protocol file untracked | <b>PASS</b> | —         |

| # | Plan ref                               | Timestamp                   | Action                                                                                     | Evidence                                                                                                                                                                                     | Verdict                                                                                                                                                                                                                                                                                | Follow-up                                                                                                                                                                                                                                                                                                       |
|---|----------------------------------------|-----------------------------|--------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2 | Sec. 2.2 (STRIPE_MODE check)           | 13:0x UTC                   | Attempted to read STRIPE_MODE/live secrets to confirm current mode                         | Harness's Credential-Materialization guard blocked using the raw Stripe secret key (even read-only, e.g. <code>curl -u "\$STRIPE_SK:"</code> ) and blocked <code>stripe config --list</code> | <b>BLOCKED (tooling boundary, not a product defect)</b>                                                                                                                                                                                                                                | Reassigning to [ME]: please confirm current mode directly in the Stripe Dashboard (top-left Test/Live toggle) — I cannot safely hold the secret key myself. Everything else in Sec. 2.2 (does the <i>app</i> actually behave correctly in live mode) is covered indirectly by Sec. 4/Sec. 14 once we get there. |
| 3 | Sec. 2.4 (webhook endpoint registered) | 13:0x UTC                   | Same blocker as above — checking registered webhook endpoints requires the same secret key | <b>BLOCKED (tooling boundary)</b>                                                                                                                                                            | Reassigning to [ME]: please check Dashboard -> Developers -> Webhooks — confirm the live endpoint is Enabled and listening for the 5 events listed in the plan. I'll cross-check indirectly in Sec. 4 by confirming a real webhook-driven DB update actually happens after a checkout. |                                                                                                                                                                                                                                                                                                                 |
| 4 | Sec. 2.5 (price ID sync)               | 13:0x UTC                   | Read <del>secret from the</del> repo (no secret needed)                                    | Cipher <code>price_1UKwmcAT2hck0lynXod1E5E</code> , Ghost <code>price_1UWAT2agm5Snp0iaEC4</code> // <code>LIVE</code> in code comments, matches the go-live commit <code>de491ba</code>      | <b>PASS</b> (static check only: live match against Stripe's own price objects is blocked the same way as #2/#3; will confirm indirectly via Sec. 4)                                                                                                                                    | —                                                                                                                                                                                                                                                                                                               |
| 5 | Sec. 2.6                               | 13:14:33 (site's own clock) | Loaded <code>/status</code> live, waited for checks to finish                              | "All systems operational" — Web App, API Platform, Sign-in/sessions, Database, Email delivery, Email provider, Breach-check provider, <b>Payment provider</b> all show "Operational"         | <b>PASS</b>                                                                                                                                                                                                                                                                            | —                                                                                                                                                                                                                                                                                                               |

| #  | Plan ref                                 | Timestamp | Action                                                                                                                                                                       | Evidence                                                                                                                                                                                                                                                                                                                                           | Verdict                                                                                                                                                                                             | Follow-up                                                                                      |
|----|------------------------------------------|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| 6  | Sec. 2.7                                 | 13:0x UTC | against ssl_client_xn--bliglmd-elace, read cert dates/issuer                                                                                                                 | Let's Encrypt case, valid, 2026-08-25 -> 2026-11-23 (>14 days remaining)                                                                                                                                                                                                                                                                           | PASS                                                                                                                                                                                                | —                                                                                              |
| 7  | Sec. 2.8                                 | —         | Requires Stripe Dashboard login (real financial-account credentials) — not something I can access                                                                            | <b>BLOCKED — assigned to [ME]</b>                                                                                                                                                                                                                                                                                                                  | Thorsten: please confirm the live payouts destination bank account in the Stripe Dashboard when convenient. Not blocking for Sec. 3 (free tier) testing, but blocking before Sec. 14 (real charge). |                                                                                                |
| 8  | Sec. 3.11 (side-effect, brought forward) | 13:06:04  | Created a disposable test signup (qa-protocol-1700087163@bliglmd-test.invalid) via the public Auth signup endpoint (anon key only, no secret) to probe consent-gate behavior | Signup succeeded, consent text required and recorded in user_metadata.signup_consent_text; email left <b>unconfirmed</b> on purpose                                                                                                                                                                                                                | <b>IN PROGRESS</b>                                                                                                                                                                                  | Re-check pending — see #16                                                                     |
| 9  | Sec. 3.1                                 | 15:1x UTC | Loaded / live, full page inventory                                                                                                                                           | Hero, trust badges, pricing cards (Trace/Cipher/Ghost), footer all present and correctly worded                                                                                                                                                                                                                                                    | PASS                                                                                                                                                                                                | —                                                                                              |
| 10 | Sec. 3.2 (real account, full path)       | 15:19 UTC | Used a real disposable inbox (litaxik603@cws-temp-mail.org — a legitimate external test mailbox, not a fabricated/spoofed address) to click "Scan email"                     | <b>Finding:</b> "Scan email" and "Get started for free" both open the AuthModal directly — there is no anonymous/pre-signup scan on this build, despite the homepage's "No credit card required" framing implying low friction. This is a UX/marketing-accuracy note, not a security or billing bug: no card is required, but an account still is. | <b>NOTE — not a defect, but flag for marketing copy review</b>                                                                                                                                      | Confirm with Thorsten whether pre-signup scanning was ever intended; if not, no action needed. |

| #  | Plan ref                  | Timestamp             | Action                                                                                                        | Evidence                                                                                                                                                                                                                    | Verdict     | Follow-up                                                                                                                   |
|----|---------------------------|-----------------------|---------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----------------------------------------------------------------------------------------------------------------------------|
| 11 | Sec. 3.8                  | 15:19 UTC             | Attempted "Create account" with the required Terms/Privacy consent checkbox left unticked                     | Submit did nothing (silently blocked, no error state) — confirmed the consent gate holds client-side                                                                                                                        | <b>PASS</b> | Minor UX note: a disabled-looking button or inline validation message would be clearer than silent no-op, but not a defect. |
| 12 | Sec. 3.9/Sec. 3.10        | 15:19:xx–15:20:35 UTC | Ticked consent, submitted signup; checked the real inbox for the confirmation email                           | Email arrived in ~1 minute, top of inbox (not spam-filtered by the mail provider), correct sender <code>no-reply@obliglomd.se</code> (no-reply)", correct subject, correct 10-minute deadline copy in Swedish, working link | <b>PASS</b> | —                                                                                                                           |
| 13 | Sec. 3.9 (link mechanics) | 15:2x UTC             | Navigated to the confirmation link ( <code>.../auth/v1/verify?base.type=signup...</code> )                    | Redirected to <code>/</code> with a valid session in the URL fragment; NavBar switched to authenticated state ("Scan email / My requests / My profile / Log out")                                                           | <b>PASS</b> | —                                                                                                                           |
| 14 | Sec. 3.4                  | 15:2x UTC             | On <code>/scan</code> , submitted the real scan email <b>without</b> ticking the XposedOrNot consent checkbox | No scan ran, no results shown, no error — clean silent block                                                                                                                                                                | <b>PASS</b> | —                                                                                                                           |

| #  | Plan ref | Timestamp | Action                                                                                                                  | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                 | Verdict                                                              | Follow-up                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|----|----------|-----------|-------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 15 | Sec. 3.4 | 15:2x UTC | Ticked consent, submitted                                                                                               | "Data breaches (0 found)" + full company directory rendered (Swedish media/utgivningsbevis group first with amber "Publishing Certificate" badges, then GDPR-obligated, opt-out, authority-tools groups) — matches the documented architecture exactly, including per-company tier availability (e.g. Ratsit/Krimfup/Lexbase correctly Trace-only, no Cipher/Ghost auto-send offered for sensitive/opt-out-only targets) | <b>PASS</b>                                                          | —                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| 16 | Sec. 3.6 | 15:2x UTC | As the free/Trace user, clicked "Send" on Spotify (a GDPR-obligated company) -> landed on <code>/request/spotify</code> | <b>Defect found:</b> the page loaded with the <b>Ghost</b> tab pre-selected by default, showing a "included in Ghost, upgrade for 199 kr/mo" paywall — even though this Trace-tier user has no Ghost access and the page itself shows Trace as an available (unlocked) tab. Manually clicking the "Trace" tab then correctly reveals real guided instructions (Spotify DPO email, GDPR deep-link).                       | <b>FAIL (minor, UX/conversion) — not a security or billing issue</b> | <b>Fixed same session</b> (commit 9d48a17, fix-forward policy): <code>Request.tsx</code> now re-points the initial tab at the user's own highest <i>unlocked</i> tier once <code>userLevel</code> loads, instead of the company's highest offered tier. <code>tsc --noEmit</code> clean, pushed to <code>main</code> . <b>Re-verified live</b> ~15 min later at <code>/request/spotify</code> : now loads directly on the Trace tab with real guided instructions, no manual click needed. <b>CLOSED.</b> |

| #  | Plan ref                       | Timestamp                                         | Action                                                                                                                                                                                                                                                              | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                     | Verdict                            | Follow-up                                                                                                                                                                                                                                                                                                                                                                                               |
|----|--------------------------------|---------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 17 | Sec. 3.11                      | ~13:26 UTC<br>(checked, elapsed ~20 min since #8) | Queried <code>auth.users</code> via <code>supabase db query</code> -- linked for both test accounts                                                                                                                                                                 | The <b>unconfirmed</b> disposable account ( <code>qa-protocol-...@bliglond-test.invalid</code> , created 13:06:04, never confirmed) is <b>gone</b> — <b>confirmed</b> account ( <code>litaxik603@cwsgear.com</code> ) still exists with <code>confirmed_at</code> expected.                                                                                                                                                  | <b>PASS</b>                        | —                                                                                                                                                                                                                                                                                                                                                                                                       |
| 18 | Sec. 3.12                      | 15:3x UTC                                         | Loaded <code>/dashboard</code> as the real (Trace) test user                                                                                                                                                                                                        | Renders correctly: "My requests", empty state ("No requests yet — Start a scan!"), "+ New scan" button                                                                                                                                                                                                                                                                                                                       | <b>PASS</b>                        | —                                                                                                                                                                                                                                                                                                                                                                                                       |
| 19 | Sec. 7.1 (critical regression) | 15:4x UTC                                         | From the browser console, using the real test user's own session JWT (no service-role/secret key involved):<br><code>PATCH /rest/v1/profiles?id=eq.&lt;self&gt; {"level":1,"subscription_status":"active"} -- the write-bug free-Ghost-access paywall bypass</code> | API responded <b>HTTP 200</b> with a row body showing <code>level:1, subscription_status:"inactive"</code> the revoked columns were <code>files?id=eq.&lt;self&gt; {"level":1,"subscription_status":"active"} rejected outright</code> . Independently confirmed against the database directly via <code>supabase db query</code> -- linked: <code>level=1, subscription_status='inactive', stripe_customer_id=null</code> . | <b>PASS</b> — bypass does not work | <b>Worth knowing, not fixing:</b> the response status is a misleading 200 rather than 403/42501 for this specific case, because the migration-027 defense-in-depth trigger ( <code>protect_profile_billing</code> ) reverts the value rather than rejecting the request outright. Functionally safe; just don't let a 200 status alone be read as "the write succeeded" if this is ever debugged again. |
| 20 | Sec. 7.3                       | 15:4x UTC                                         | Same session, <code>DELETE /rest/v1/profiles</code> -- the historical self-delete-bypasses-table bug                                                                                                                                                                | 403 42501 permission denied for <code>q.&lt;self&gt;</code> profiles, with PostgreSQL's own hint confirming <code>DELETE</code> is not granted to <code>authenticated</code>                                                                                                                                                                                                                                                 | <b>PASS</b>                        | —                                                                                                                                                                                                                                                                                                                                                                                                       |

| #  | Plan ref             | Timestamp | Action                                                                                                     | Evidence                                                                                                                                                                                                                                             | Verdict                                                                                                                                               | Follow-up |
|----|----------------------|-----------|------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|
| 21 | Sec. 7.2             | 15:4x UTC | Same session, POST (a real test/v1/rpc admin-only RPC named in the plan) as a non-admin authenticated user | 403 42501 permission denied forle_requests admin_stale_requests                                                                                                                                                                                      | PASS                                                                                                                                                  | —         |
| 22 | Sec. 7.2 (info only) | 15:4x UTC | Same test against rpc/is_admin                                                                             | 200, returned false — this one RPC is callable by any authenticated user, but only returns a boolean and exposes nothing; consistent with it being a client-side "am I admin" helper, not a data-exposure risk                                       | PASS (as designed)                                                                                                                                    | —         |
| 23 | Sec. 4.1             | 16:0x UTC | As the real Trace test user, clicked "Choose Cipher" on /                                                  | New "BEFORE YOU PAY" pre-checkout consent modal appeared — key terms summary + ångerrätt-waiver checkbox, version 2026-09-25-v4, matching the live Terms page exactly. Attempted to proceed without ticking consent first -> blocked, no navigation. | PASS (this also directly answers Sec. 8.3: the waiver is captured as an explicit, timestamped step at time of purchase, separate from signup consent) | —         |

| #  | Plan ref                  | Timestamp | Action                                                                                 | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Verdict     | Follow-up                                                                          |
|----|---------------------------|-----------|----------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|------------------------------------------------------------------------------------|
| 24 | Sec. 4.1<br>(continued)   | 16:0x UTC | Ticked consent,<br>clicked "I agree<br>— proceed to<br>payment"                        | Redirected to a<br><b>real live</b> Stripe<br>Checkout<br>session<br>(cs_live_...,<br>id redacted from<br>this log) — this<br>by itself confirms<br><del>that the mode</del><br><b>stripe-mode=live</b><br>live price ID are<br>correctly wired<br>end to end,<br>closing out Sec.<br>2.2 and Sec. 2.5<br>indirectly (no<br>secret key<br>needed — the<br>app told us by<br>behaving<br>correctly). Page<br>showed correct<br>branding<br>"BliGlömd.se",<br>"Subscribe to<br>Cipher", <b>SEK<br/>99.00/month</b> ,<br>"Total due today<br>SEK 99.00",<br>promo-code field<br>present. <b>Noted<br/>in passing:<br/>Klarna is now<br/>offered as a<br/>payment<br/>method</b><br>alongside card<br>— this was an<br>open "pending,<br>needs manual<br>activation" item<br>in prior project<br>notes; looks like<br>it's live now.<br><b>Stopped here</b><br>— did not enter<br>card data or<br>submit payment,<br>per the plan's<br>fixed boundary<br>(Sec. 0, Sec.<br>14). | <b>PASS</b> | Flag for<br>Thorsten:<br>confirm Klarna<br>activation was<br>intentional/expected. |
| 25 | Sec. 4.1 (cancel<br>path) | 16:0x UTC | Clicked "Back to<br>BliGlömd.se"<br>(Stripe's own<br>cancel link)<br>instead of paying | Correctly<br>returned to<br>/profile<br>(matches<br>cancel_url<br>in<br>stripe-checkout's<br>code)                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         | <b>PASS</b> | —                                                                                  |

| #  | Plan ref                           | Timestamp | Action                                                                                  | Evidence                                                                                                                                                                                                                                                                                                      | Verdict | Follow-up                                                                                                                                                                                                               |
|----|------------------------------------|-----------|-----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 26 | Sec. 13.6<br>(brought forward)     | 16:0x UTC | Verified DB state after the cancelled checkout                                          | level=1, subscription_status='inactive', stripe_subscription_id=stripe_customer_id<br>real live Stripe customer id, redacted from this log), because the edge function creates the Stripe Customer object eagerly, before checkout, by design. No half-upgraded/orphaned state.                               | PASS    |                                                                                                                                                                                                                         |
| 27 | Sec. 3.14/Sec. 4<br>(profile page) | 16:0x UTC | Loaded /profile post-cancel                                                             | "Your current plan: Trace" (correctly not upgraded), name/email edit fields, "Upgrade to Cipher"/"Upgrade to Ghost" buttons, delete-account section all render                                                                                                                                                | PASS    | Note: no monthly/annual toggle visible on these upgrade buttons — if annual billing was meant to be exposed here, it isn't yet (matches an old known pending item in project notes; not a regression, just still open). |
| 28 | Sec. 5.1                           | 16:1x UTC | Same test account, clicked "Choose Ghost" from /                                        | Same "BEFORE YOU PAY" consent modal, correct Ghost terms/version. Ticked, proceeded -> real live Stripe Checkout, correct branding, "Subscribe to Ghost", SEK 199.00/month, promo field present, Klarna offered. Stopped before payment; cancelled via "Back to BliGlömd.se" -> landed on /profile correctly. | PASS    | —                                                                                                                                                                                                                       |
| 29 | Sec. 13.2                          | 16:2x UTC | On a fresh live Cipher checkout session, entered an invalid promo code (INVALIDCODE123) | "This code is invalid." shown inline, total stayed SEK 99.00, no crash                                                                                                                                                                                                                                        | PASS    | —                                                                                                                                                                                                                       |

| #  | Plan ref                  | Timestamp | Action                                                                                                                                                           | Evidence                                                                                                                                                                                                                                              | Verdict     | Follow-up |
|----|---------------------------|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|-----------|
| 30 | Sec. 13.3                 | 16:2x UTC | Same session, entered the real live promo code <b>GL0MD10</b>                                                                                                    | Applied correctly: "-SEK 9.90", "10% off for a month", total dropped to <b>SEK 89.10</b> , with "Then SEK 99.00 per month starting next month" shown — confirms both the discount math and the one-time-only duration are correct in <b>live</b> mode | <b>PASS</b> | —         |
| 31 | (cleanup)                 | 16:2x UTC | Cancelled via "Back to BliGlömd.se"                                                                                                                              | Landed on <b>/profile</b> , no charge, no promo code consumed (Stripe promo codes aren't consumed until actual payment)                                                                                                                               | <b>PASS</b> | —         |
| 32 | Sec. 8.1 (re-confirm)     | 16:2x UTC | Re-read <b>/privacy</b> while logged in                                                                                                                          | Version 2026-09-29-v8, org number 969797-1647 disclosed (Sec. 8.5), XposedOrNot disclosure text matches the scan-page consent checkbox wording exactly (Sec. 8.6)                                                                                     | <b>PASS</b> | —         |
| 33 | Sec. 3.15 (negative case) | 16:3x UTC | Clicked "Delete my account" -> typed-confirmation UI appeared. Checked the "Yes, delete everything" button's <b>disabled</b> state <b>before</b> typing anything | <del>disabled</del> <b>disabled</b> HTML true attribute, not just a visual/CSS block                                                                                                                                                                  | <b>PASS</b> | —         |
| 34 | Sec. 3.15                 | 16:3x UTC | Typed the exact word "delete" into the confirmation field ( <b>#profile-delete-confirm-word</b> , placeholder <b>delete</b> )                                    | Button became enabled ( <b>disabled: false</b> )                                                                                                                                                                                                      | <b>PASS</b> | —         |
| 35 | Sec. 3.15 (execution)     | 16:3x UTC | Clicked "Yes, delete everything"                                                                                                                                 | Redirected to <b>/</b> in logged-out state (NavBar shows "Log in" again)                                                                                                                                                                              | <b>PASS</b> | —         |

| #  | Plan ref                            | Timestamp | Action                                                                                                                                                                                                                                  | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                                | Verdict | Follow-up                                                                                                                                          |
|----|-------------------------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| 36 | Sec. 3.15<br>(cascade verification) | 16:3x UTC | Queried <code>auth.users</code> , <code>public.profiles</code> , <code>public.analytics_events</code> , <code>public.consent_records</code> , <code>public.signup_consent_records</code> , directly to signup endpoint, deleted user id | All 5 tables: 0 rows. Genuinely total deletion, not even to delete records, consent records situation — this is real, verified evidence behind the Privacy Policy Sec. 5 claim "Deletion is total: everything is removed... and cannot be recovered," not just a trust-the-copy assumption                                                                                                                                              | PASS    | —                                                                                                                                                  |
| 37 | Sec. 3.16                           | 16:3x UTC | Re-signed up with the same email ( <code>litaxik603@cws@gmail.com</code> ) immediately after deletion, via the public signup endpoint                                                                                                   | 200, new account created cleanly, no "email already registered" error                                                                                                                                                                                                                                                                                                                                                                   | PASS    | New unconfirmed account left in place — will be auto-cleaned by the same 10-minute cron as before; no manual cleanup needed.                       |
| 38 | Sec. 10.2                           | 16:4x UTC | Queried <code>cron.job</code> and <code>cron.job_run_data</code> scheduled jobs                                                                                                                                                         | All 8 active ( <code>admin-monthly-report</code> , <code>admin-weekly-db-dump</code> , <code>admin-weekly-digest</code> , <code>cleanup-analytics-events</code> , <code>cleanup-audit-logs</code> , <code>cleanup-unconfirmed-accounts</code> , <code>send-followups-daily</code> , <code>send-reminders-daily</code> ); most recent run of each = succeeded; <code>cleanup-unconfirmed-accounts</code> every 5 min exactly as designed | PASS    | <code>admin-monthly-report</code> has no run history yet — expected, it's scheduled for the 1st of the month and today is the 29th, not a failure. |

| #  | Plan ref                 | Timestamp | Action                                                                                                                                  | Evidence                                                                                                                                                                                                                                                                                                                                                                                                                                                  | Verdict                                                                              | Follow-up                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|----|--------------------------|-----------|-----------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 39 | Sec. 10.1 (real finding) | 16:4x UTC | Compared (supabase/migrations file) against the database (supabase/migrations/001-003)ma_migration-applied-migration bookkeeping table) | <b>Only 3 of 35 migrations are recorded</b><br>Migrations 004–035 are genuinely applied — confirmed independently, since the tables/functions/crons they create all exist and work correctly (analytics_events, consent tables, admin lockdown, etc.) — but were applied via <code>supabase db query -f</code> per this project's standard workflow, which doesn't write to this tracking table the way <code>supabase db push/migration up</code> would. | <b>FAIL (operational risk, not a divet-breaking bug) — NOT fixed</b> , see follow-up | I generated a reconciliation script (INSERT the 32 missing version/name/statements rows, ON CONFLICT DO NOTHING, pure bookkeeping — doesn't touch schema or data) but writing it was <b>blocked by the harness</b> ("Modify Shared Resources" — a direct production DB metadata write). <b>This needs Thorsten to run it</b> , or explicitly authorize me to. Risk if left as-is: a future <code>supabase db push or migration up</code> could try to re-apply migrations 004–035 from scratch and fail/conflict, since the CLI would believe they were never run. I did not retry via a different path after the block — see the guide/prompt list for what to do here. |
| 40 | Sec. 12                  | 16:5x UTC | Resized to mobile (375×812), spot-checked / (hero + pricing cards)                                                                      | Clean layout, no horizontal overflow, cards stack correctly, cookie notice bar doesn't obscure primary CTAs                                                                                                                                                                                                                                                                                                                                               | <b>PASS</b>                                                                          | —                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |